DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Project details

Title of the Project: - Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk

Abstract

This project focuses on designing and implementing a context-aware access control framework to improve the security of modern web applications and organizational systems. Traditional security methods that rely only on usernames and passwords are no longer sufficient to protect sensitive information from modern cyber threats. The proposed system follows a Zero Trust security approach, where access is granted only after evaluating multiple contextual factors such as user identity, device posture, location, and application risk. This ensures that only authorized users with secure devices can access specific applications.

The framework integrates security mechanisms such as identity-based authentication, multi-factor authentication (MFA), device compliance verification, and policy-based access control to enforce least-privilege access. Based on the access context, the system can allow access, restrict certain actions, request additional authentication, or block the request. For example, users accessing applications from trusted devices and locations receive normal access, while users connecting from unusual locations or high-risk networks may receive restricted or monitored access.

To strengthen system security, vulnerability assessment and security testing were performed using tools such as Nessus Scanner, Burp Suite, Kali Linux, and Uniscan. These tools helped identify vulnerabilities including Cross-Site Scripting (XSS), SQL Injection, and information exposure. The project demonstrates how context-aware access control and regular security testing can help organizations protect sensitive applications and maintain secure access in modern digital environments.

Use Case Scenarios:

Scenario 1: Finance Department Access to ERP System

A senior accountant needs remote access to the company's ERP system to process payroll using a company laptop. The user logs in through the ZPA Client Connector and authenticates using Azure Active Directory with MFA. ZPA verifies the user's identity, Finance_ERP_Users group membership, and device posture. After verification, the system allows access only to the ERP application through a secure micro-tunnel.

Output:

• User authenticated based on identity and group membership
• Other internal systems remain hidden

Scenario 2: Contractor Access to Project Repository

An external contractor working on a project needs access to a specific Git repository. The contractor is added to the Project_X_Contractors group and connects using the ZPA client. The system verifies the user's identity and device compliance before granting access only to the repository during working hours.

Output:

• Time-based access control enforced.
• Access limited to the Git repository.
• Other internal resources blocked

Scenario 3: Executive Access to Sensitive Documents

A company executive needs to access confidential SharePoint documents while traveling abroad. After authentication with Azure Active Directory and MFA, ZPA verifies identity and device compliance. Because the login location is unusual, the system provides restricted read-only access and monitors the session.

Output:

• User authenticated but flagged for unusual location.

• Read-only access with download restrictions.

• Security team notified for monitoring.

Scenario 4: Remote Support Technician Access

An IT support technician needs access to ServiceNow and a remote desktop tool to assist employees. The technician logs in through the ZPA Client Connector and authenticates with MFA. ZPA verifies identity, device posture, and trusted location before granting access only to the required support tools.

Output:

• User authenticated and authorized.

• Secure access provided to support tools.

• Other internal systems remain inaccessible.

Scenario 5: High-Risk Access from Public Network

A marketing employee needs to access Salesforce CRM from a public Wi-Fi network using a company smartphone. After authentication with MFA, ZPA verifies the device but marks the network as high-risk. The system allows access through secure browser isolation to protect sensitive data.

Output:

• User authenticated but network considered high-risk.

• Access provided through browser isolation.

• Data protected with restricted actions.

STAGE 1

Title Of The Project: -Design and Apply Context-Aware Access Controls Based On User Identity, Device Posture, Location, and Application Risk.

OVERVIEW:

In today's digital environment, organizations face many cybersecurity threats when users access systems from different locations and devices. Traditional security methods that rely only on usernames and passwords are no longer sufficient to protect sensitive data and applications. As organizations adopt cloud services, remote work, and mobile devices, the risk of unauthorized access and data breaches continues to increase.

This project focuses on designing and applying context-aware access control, which is a modern security approach that evaluates multiple factors before allowing access to an application. These factors include the user's identity, the security condition of the device, the location from which the user is accessing the system, and the risk level of the application. By analyzing these contextual parameters, the system ensures that only authorized and trusted users are able to access specific resources.

The system analyzes these conditions in real time and decides whether to allow access, restrict certain actions, request additional authentication such as multi-factor authentication (MFA), or block the access completely. This dynamic decision-making process helps reduce security risks and prevents unauthorized users from accessing sensitive information.

List of teammates

S.NO	NAME	COLLEGE	CONTACT
1	Poojasri P	KPR College of Arts Science and Research	23bda044@kprcas.ac.in
2	Hema Vikashini S	KPR College of Arts Science and Research	23bda029@kprcas.ac.in
3	Hirthika K	KPR College of Arts Science and Research	23bda030@kprcas.ac.in
4	Ilakkiyaa K	KPR College of Arts Science and Research	23bda031@kprcas.ac.in

List of Vulnerability Table

S.NO	VULNERBILITY NAME	CWE/CVE - NO
1	Cross Site Scripting (Stored)	CWE-79
2	Broken Access Control	CWE-285
3	SQL Injection	CWE- 89
4	Broken Authentication	CWE- 285
5	Insecure Direct Object Reference	CWE- 639

6	Security Misconfiguration	CWE- 732
7	Cross Site Request Forgery	CWE- 352
8	Cleartext Transmission of Sensitive Information	CWE- 319
9	Clickjacking	CWE-1021
10	Password Auto Completion Enabled	CWE- 310

REPORT: -

1.Vulnerability Name: Cross-Site Scripting (Stored)

CWE/CVE: - CWE-79

Description : Cross-Site Scripting (XSS) is a web security vulnerability where attackers insert malicious scripts into a web application. These scripts are stored in the server and later executed in the browser of other users who visit the affected page.

Business Impact : This vulnerability can allow attackers to steal sensitive information such as user credentials, session cookies, or personal data. It can also allow attackers to perform actions on behalf of legitimate users.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter:http://testfire.net/search.jsp?query='>alert('hacked')

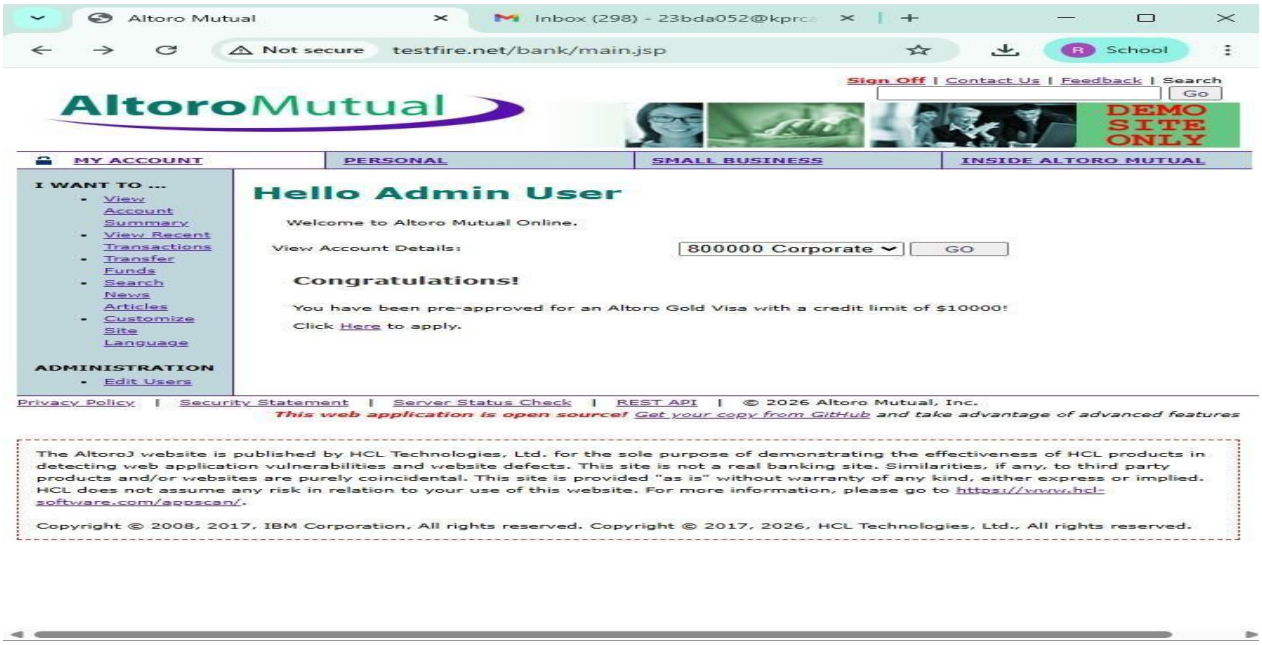
Recommendation:

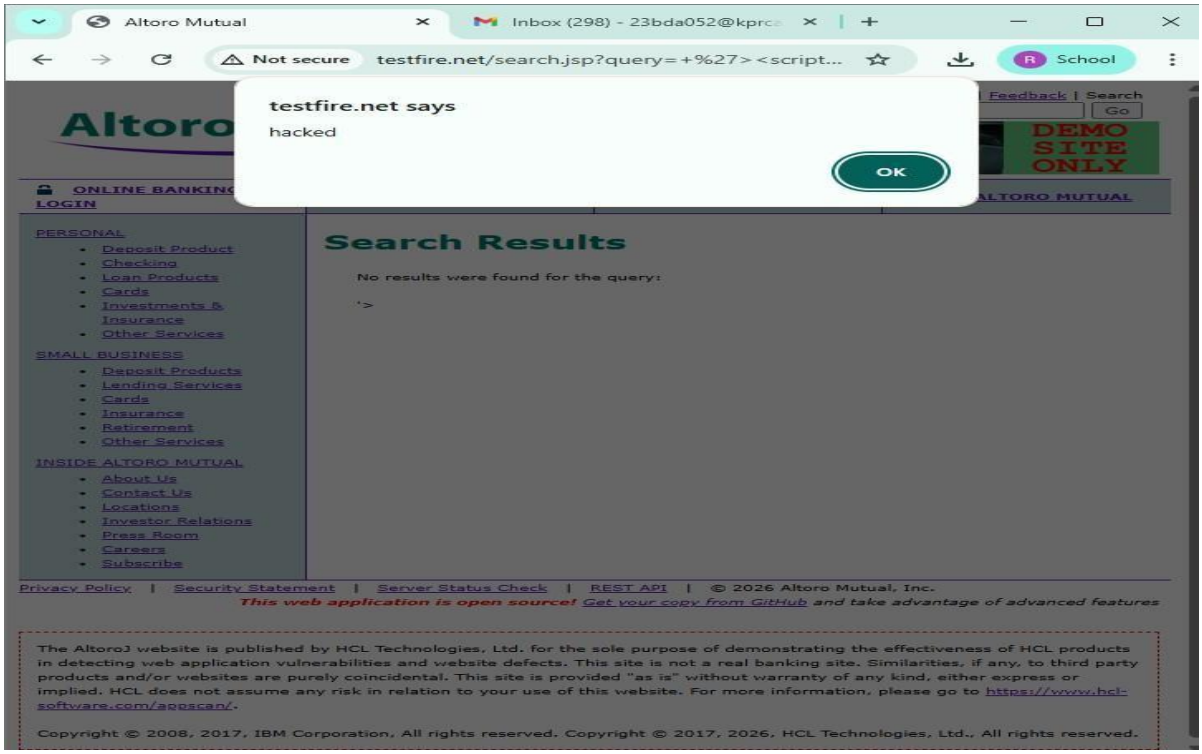
Validate and sanitize all user inputs.

Use output encoding to prevent script execution.

Implement secure coding practices to prevent injection attacks.

Screenshot:


Altoro Mutual
Inbox (298) - 23bda052@kprc
Not secure
testfire.net/bank/main.jsp
School
Sign Off | Contact Us | Feedback | Search
Go
AltoroMutual
DEMO SITE ONLY
MY ACCOUNT
PERSONAL
SMALL BUSINESS
INSIDE ALTORO MUTUAL
I WANT TO ...
View Account Summary
View Recent Transactions
Transfer Funds
Search News Articles
Customize Site Language
ADMINISTRATION
Edit Users
Hello Admin User
Welcome to Altoro Mutual Online.
View Account Details:
800000 Corporate
GO
Congratulations!
You have been pre-approved for an Altoro Gold Visa with a credit limit of $10000!
Click Here to apply.
Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc.
This web application is open source! Get your copy from GitHub and take advantage of advanced features
The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.
Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.


Altoro Mutual
Inbox (298) - 23bda052@kprc
Not secure
testfire.net/search.jsp?query=+%27><script...
School
testfire.net says
hacked
OK
Feedback | Search
Go
DEMO SITE ONLY
ONLINE BANKING LOGIN
PERSONAL
Deposit Product
Checking
Loan Products
Cards
Investments & Insurance
Other Services
SMALL BUSINESS
Deposit Products
Lending Services
Cards
Insurance
Retirement
Other Services
INSIDE ALTORO MUTUAL
About Us
Contact Us
Locations
Investor Relations
Press Room
Careers
Subscribe
Search Results
No results were found for the query:
'>
Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc.
This web application is open source! Get your copy from GitHub and take advantage of advanced features
The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.
Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

2.Vulnerability Name : Broken Access Control

CWE/CVE: - CWE-285

Description : Broken Access Control occurs when a system does not properly restrict users from accessing data or functions that they are not authorized to use.

Business Impact : Attackers may gain unauthorized access to sensitive data, modify user information, or perform administrative actions.

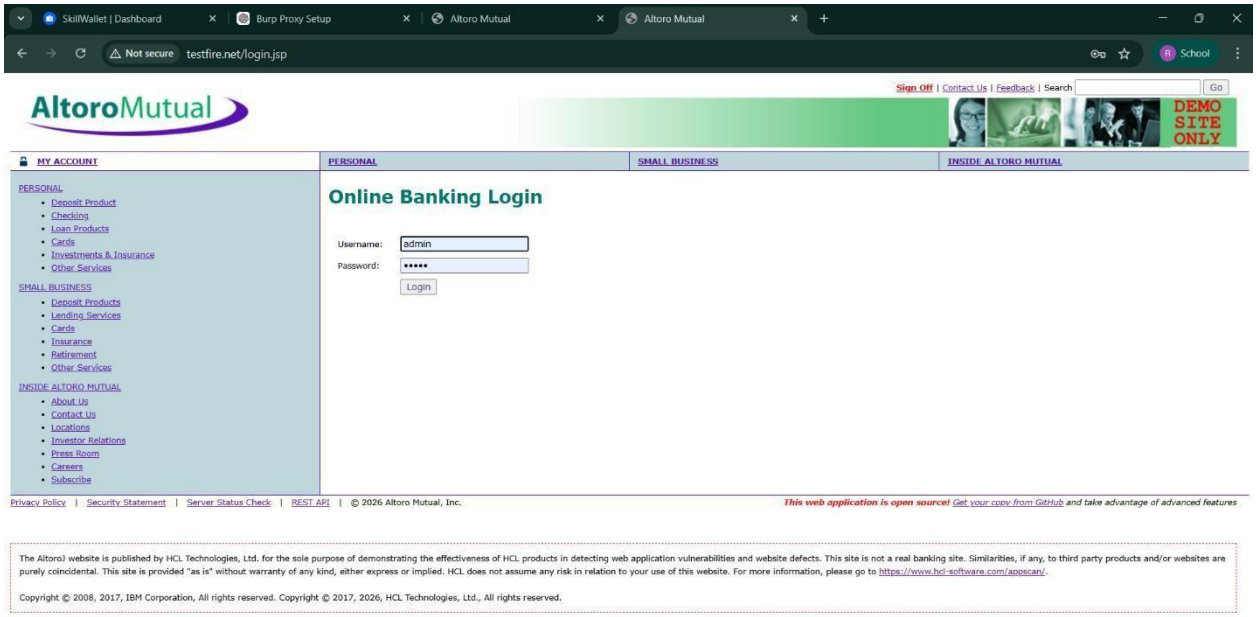
Vulnerability Path : http://testfire.net/login.jsp

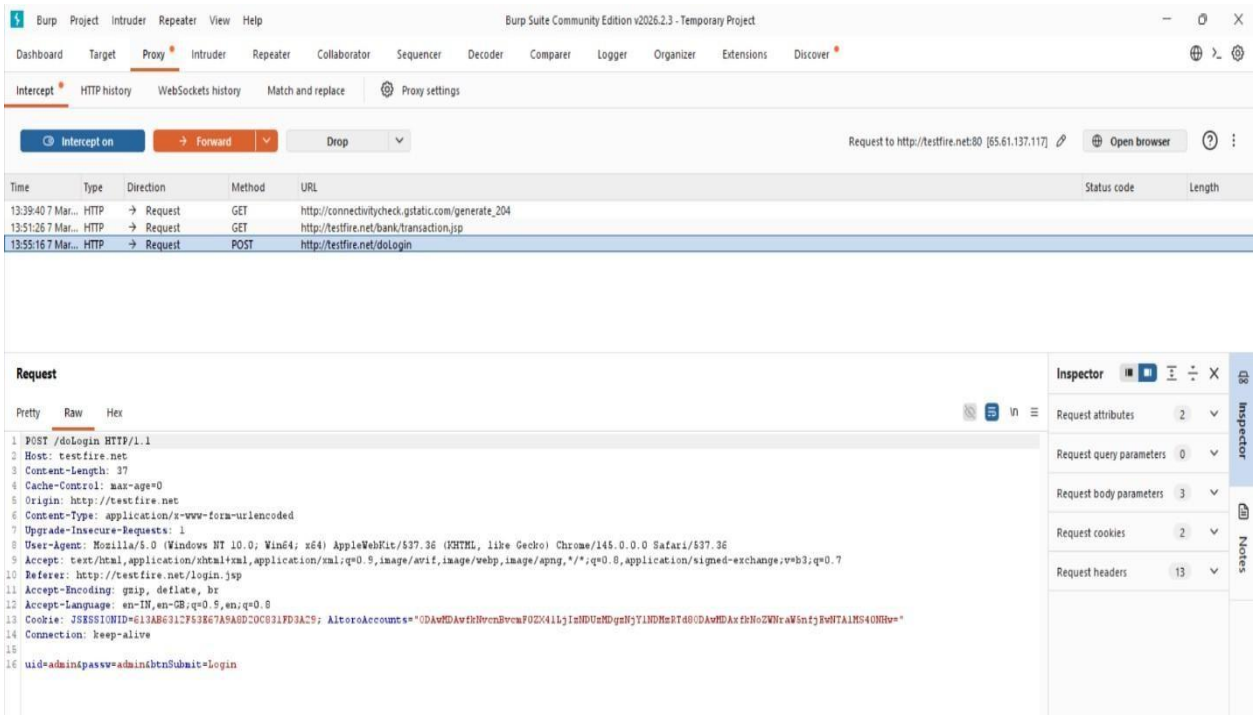
Recommendation :

Implement strong authentication and authorization mechanisms.

Use secure session management to protect user access.

Screenshot :





3.Vulnerability Name : SQL Injection

CWE/CVE: - CWE-89

Description : SQL Injection occurs when an attacker inserts malicious SQL queries into input fields to manipulate the database.

Business Impact : Attackers can access sensitive data, modify database records, or gain unauthorized administrative access.

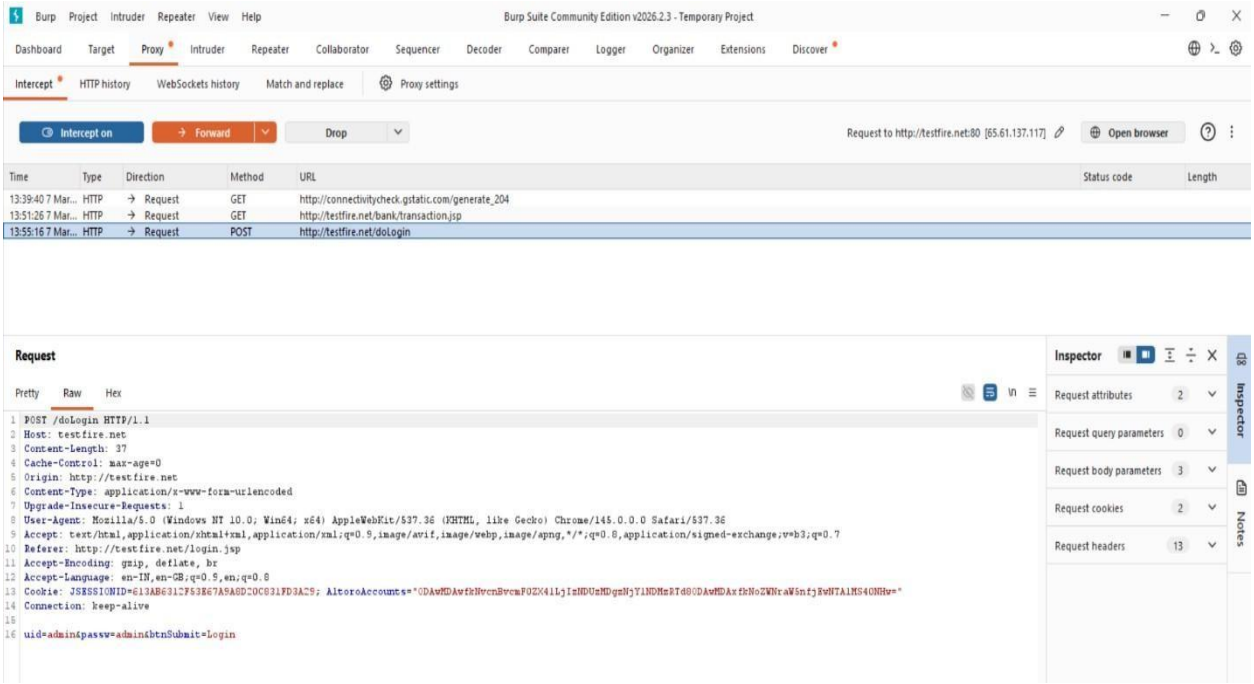
Vulnerability Path : http://testfire.net/login.jsp

Recommendation :

Use parameterized queries or prepared statements.

Validate and sanitize all user inputs.

Screenshot:



4.Vulnerability Name : Broken Authentication

CWE/CVE: - CWE-285

Description : Broken Authentication occurs when the system fails to properly manage user authentication. Attackers can bypass login mechanisms and access other user accounts.

Business Impact : Attackers may gain unauthorized access to user accounts and sensitive information.

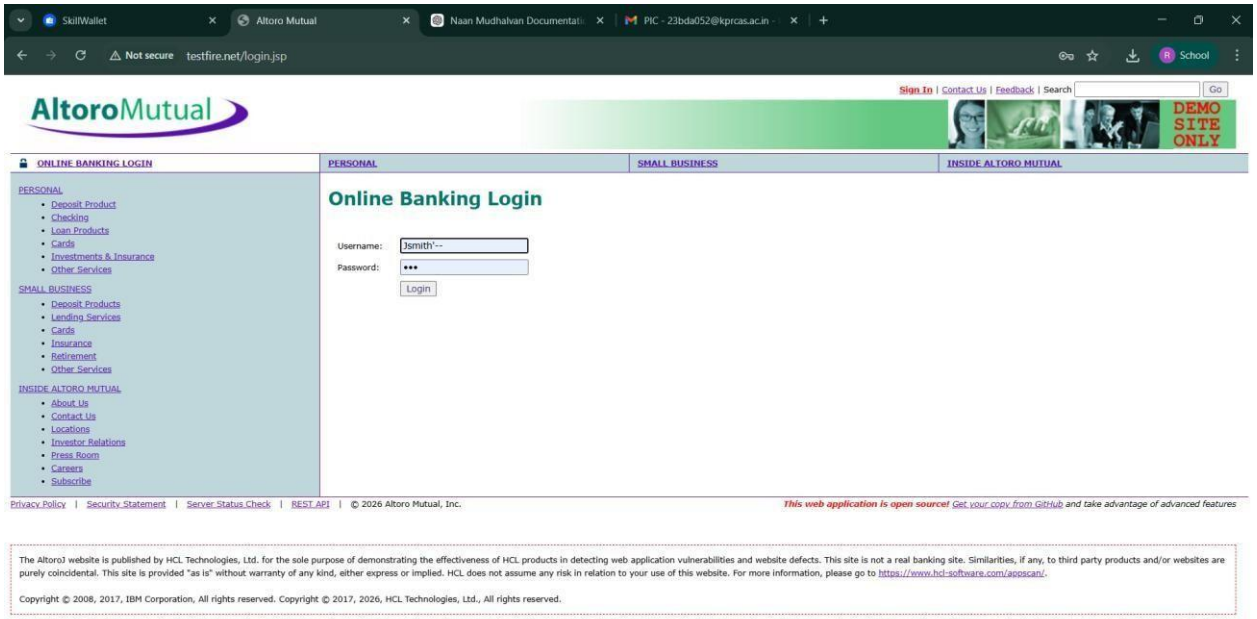
Vulnerability Path : http://testfire.net/login.jsp

Recommendation :

Implement strong authentication mechanisms such as Multi-Factor Authentication (MFA).

Use secure password storage and proper session management.

Screenshot:



5.Vulnerability Name : Insecure Direct Object Reference (IDOR)

CWE/CVE: - CWE-639

Description : IDOR occurs when a web application allows users to access or modify data by changing object identifiers such as user IDs or parameters in the URL.

Business Impact : Attackers can access or modify sensitive information of other users without proper authorization.

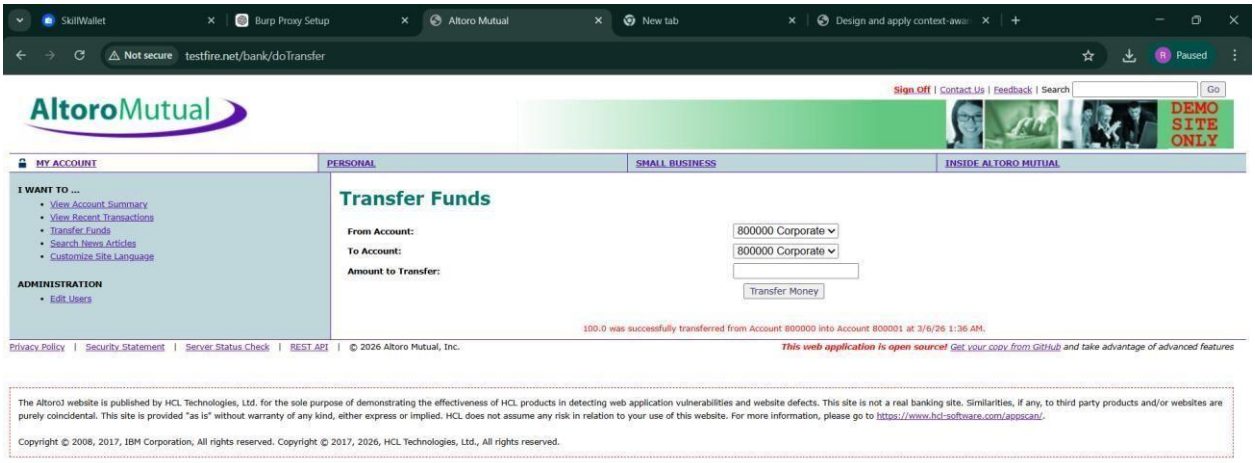
Vulnerability Path : **http://testfire.net/bank/transfer.jsp**

Recommendation :

Implement proper access control checks.

Validate user permissions before allowing access to sensitive data.

Screenshot:



6.Vulnerability Name : Security Misconfiguration

CWE/CVE: - CWE-732

Description : Security Misconfiguration occurs when systems are not securely configured, allowing unauthorized access to sensitive files or directories.

Business Impact : Attackers may access confidential information, system files, or hidden directories due to weak security settings.

Vulnerability Path : **http://testfire.net/**

Recommendation :

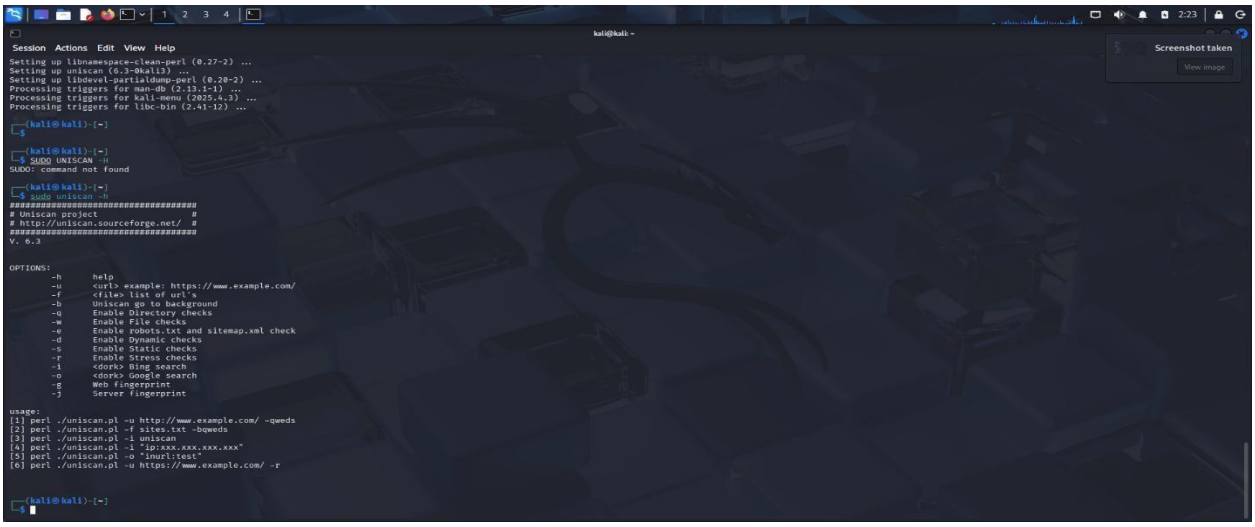
Apply secure configuration settings for servers and applications.

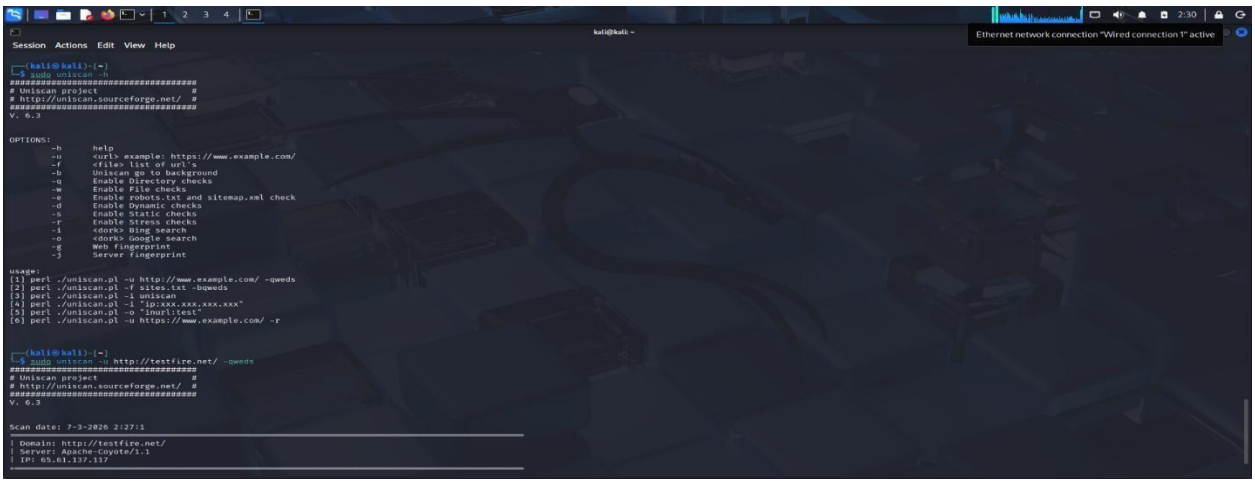
Regularly perform security audits and vulnerability scans.

Screenshot :

```
Session  Actions  Edit  View  Help
Setting up libnamespace-clean-perl (0.27-2) ...
Setting up uniscan (6.3-0kali3) ...
Setting up libdevel-partialdump-perl (0.20-2) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.4.3) ...
Processing triggers for libc-bin (2.41-12) ...

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$ SUDO UNISCAN -H
SUDO: command not found

┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3


OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r


┌──(kali㉿kali)-[~]
└─$
```

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3


OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r


┌──(kali㉿kali)-[~]
└─$ sudo uniscan -u http://testfire.net/ -qweds
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3


Scan date: 7-3-2026 2:27:1
============================================================
| Domain: http://testfire.net/
| Server: Apache-Coyote/1.1
| IP: 65.61.137.117
============================================================
```





7.Vulnerability Name : Cross-Site Request Forgery (CSRF)

CWE/CVE: - CWE-352

Description : CSRF is an attack that tricks a logged-in user into performing unwanted actions on a web application without their knowledge.

Business Impact : Attackers can perform actions such as transferring funds or changing user data using the victim's authenticated session.

Vulnerability Path : **http://testfire.net/bank/transfer.jsp**

Steps to Reproduce :

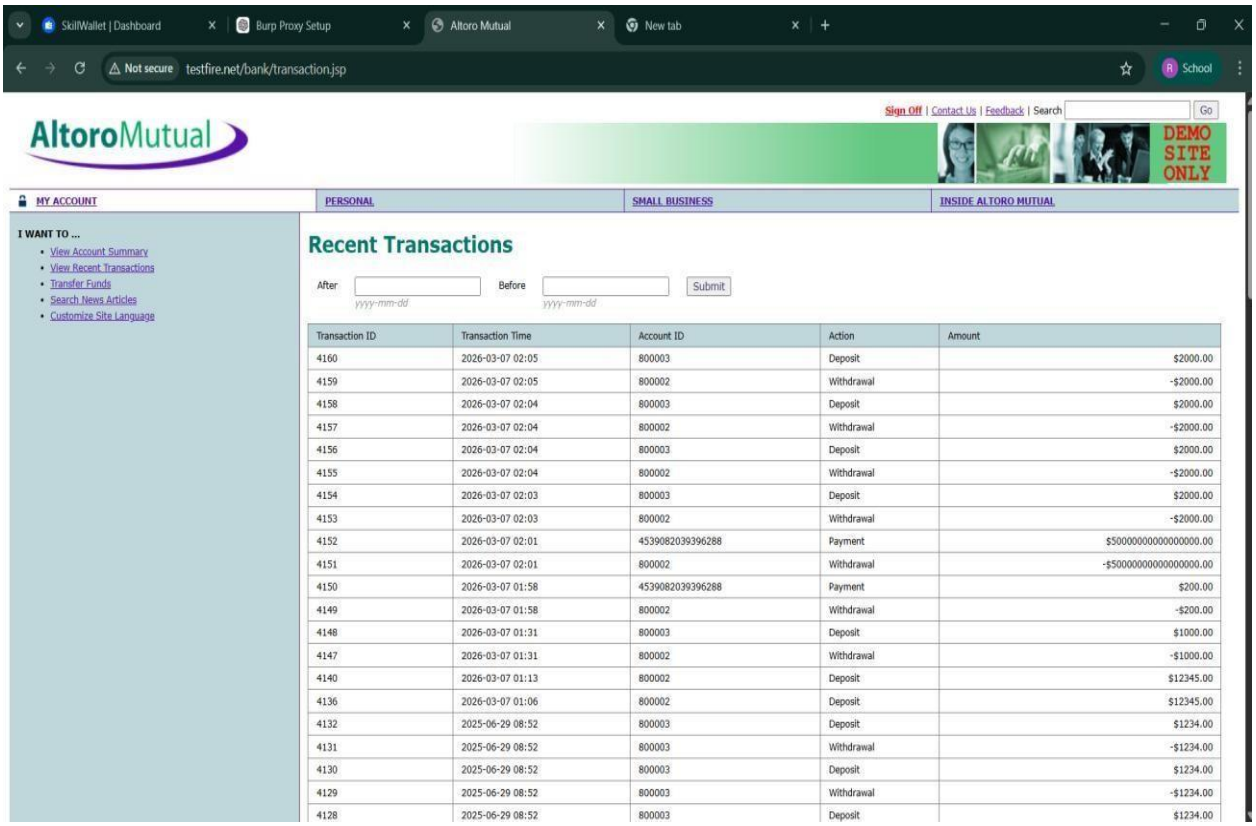
1. Open the website **http://testfire.net/**.
2. Login using valid credentials.
3. Capture the transfer request using Burp Suite.
4. Generate a CSRF proof-of-concept request to perform the action.

Recommendation :

Implement CSRF tokens to validate requests.

Use secure session management techniques.

Screenshot :



Transaction ID	Transaction Time	Account ID	Action	Amount
4160	2026-03-07 02:05	800003	Deposit	$2000.00
4159	2026-03-07 02:05	800002	Withdrawal	-$2000.00
4158	2026-03-07 02:04	800003	Deposit	$2000.00
4157	2026-03-07 02:04	800002	Withdrawal	-$2000.00
4156	2026-03-07 02:04	800003	Deposit	$2000.00
4155	2026-03-07 02:04	800002	Withdrawal	-$2000.00
4154	2026-03-07 02:03	800003	Deposit	$2000.00
4153	2026-03-07 02:03	800002	Withdrawal	-$2000.00
4152	2026-03-07 02:01	4539082039396288	Payment	$50000000000000000.00
4151	2026-03-07 02:01	800002	Withdrawal	-$50000000000000000.00
4150	2026-03-07 01:58	4539082039396288	Payment	$200.00
4149	2026-03-07 01:58	800002	Withdrawal	-$200.00
4148	2026-03-07 01:31	800003	Deposit	$1000.00
4147	2026-03-07 01:31	800002	Withdrawal	-$1000.00
4140	2026-03-07 01:13	800002	Deposit	$12345.00
4136	2026-03-07 01:06	800002	Deposit	$12345.00
4132	2025-06-29 08:52	800003	Deposit	$1234.00
4131	2025-06-29 08:52	800003	Withdrawal	-$1234.00
4130	2025-06-29 08:52	800003	Deposit	$1234.00
4129	2025-06-29 08:52	800003	Withdrawal	-$1234.00
4128	2025-06-29 08:52	800003	Deposit	$1234.00

Burp Project Intruder Repeater View Help — Burp Suite Community Edition v2

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder | Comparer | Logger

Intercept | HTTP history | WebSockets history | Match and replace | Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Exten
19	http://testfire.net	POST	/bank/doTransfer	✓		302	297		

Request

Pretty | Raw | Hex

```
1  POST /bank/doTransfer HTTP/1.1
2  Host: testfire.net
3  Content-Length: 79
4  Cache-Control: max-age=0
5  Origin: http://testfire.net
6  Content-Type: application/x-www-form-urlencoded
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
9  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
   ge/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://testfire.net/bank/doTransfer
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-IN,en-GB;q=0.9,en;q=0.8
13 Cookie: JSESSIONID=613AB6312F53E67A9A8D20C831FD3A29; AltoroAccounts=
   "ODAwMDAyflNhdmluZ3N+MTAzNzgxNC40MTk50Tk50Tk5fDgwMDAwM35DaGVja2luZ340LjczNzg20T
   c2MzEyMDE4MOUyMHw0NTM5MDgyMDM5Mzk2Mjg4fkNyZWRpdCBDYXJkfi050S410Hw="
14 Connection: keep-alive
15
16 fromAccount=800002&toAccount=800003&transferAmount=2000&transfer=Transfer+Money
```

Response

Pretty | Raw | Hex | Re

```
1  HTTP/1.1 200 OK
2  Server: Apache-Coyote/
3  Content-Type: text/htm
4  Content-Length: 7360
5  Date: Sat, 07 Mar 2026
6
7
8
9
10
11
12
13
14 <!-- BEGIN HEADER -->
15 <!DOCTYPE html PUBLIC
   "http://www.w3.org/TR/
16
17 <html xmlns="http://ww
18
19
20
21   <head>
22     <title>
         Altoro Mutual
       </title>
23     <meta http-equiv="
24     <link href="/style
25   </head>
26   <body style="margin-
27
28     <div id="header" s
29       <form id="frmSea
```

Burp Project Intruder Repeater View Help — Burp Suite Community Edition v2026.2.3 - Temporary Pro...

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder

Comparer | Logger | Organizer | Extensions | Discover

1 ×

Send | Cancel | Target: http://testfire.net | HTTP/1

Request

Pretty | Raw | Hex

```
11 Accept-Encoding: gzip, deflat
12 Accept-Language: en-IN,en-GB;
13 Cookie: JSESSIONID=613AB6312F
   AltoroAccounts=
   "ODAwMDAyflNhdmluZ3N+MTAzNzgx
   35DaGVja2luZ340LjczNzg20Tc2Mz
   5Mzk2Mjg4fkNyZWRpdCBDYXJkfi05
14 Connection: keep-alive
15
16 fromAccount=800002&toAccount=
   2000&transfer=Transfer+Money
```

Search

Response

Scan
Send to Intruder Ctrl+I
Send to Repeater Ctrl+R
Send to Sequencer
Send to Comparer
Send to Decoder
Send to Organizer Ctrl+O
Insert Collaborator payload
Request in browser
Engagement tools [Pro version only] > Find references / Discover content / Schedule task / Generate CSRF PoC
Change request method
Change body encoding
Copy Ctrl+C
Copy prettified Ctrl+Alt+C
Copy URL
Copy as curl command (bash)
Save selected text to file
Paste text from file
Save item
Save entire history
Paste host / URL as request
Add to site map
Convert selection
URL-encode as you type
Cut Ctrl+X
Copy Ctrl+C
Paste Ctrl+V
Message editor documentation
Burp Repeater documentation

Inspector: est attributes 2 | est query parameters 0 | est body parameters 4 | est cookies 2 | 13

Inspector | Notes | Custom actions

Ready

Event log (81) | All issues | 150.1MB of 3.67GB | Disabled

8.Vulnerability Name : Cleartext Transmission of Sensitive Information

CWE/CVE: - CWE-319

Description : This vulnerability occurs when sensitive information such as usernames and passwords is transmitted without encryption over the network.

Business Impact : Attackers can intercept network traffic and capture sensitive information, leading to data breaches and unauthorized access.

Vulnerability Path : http://testfire.net/login.jsp

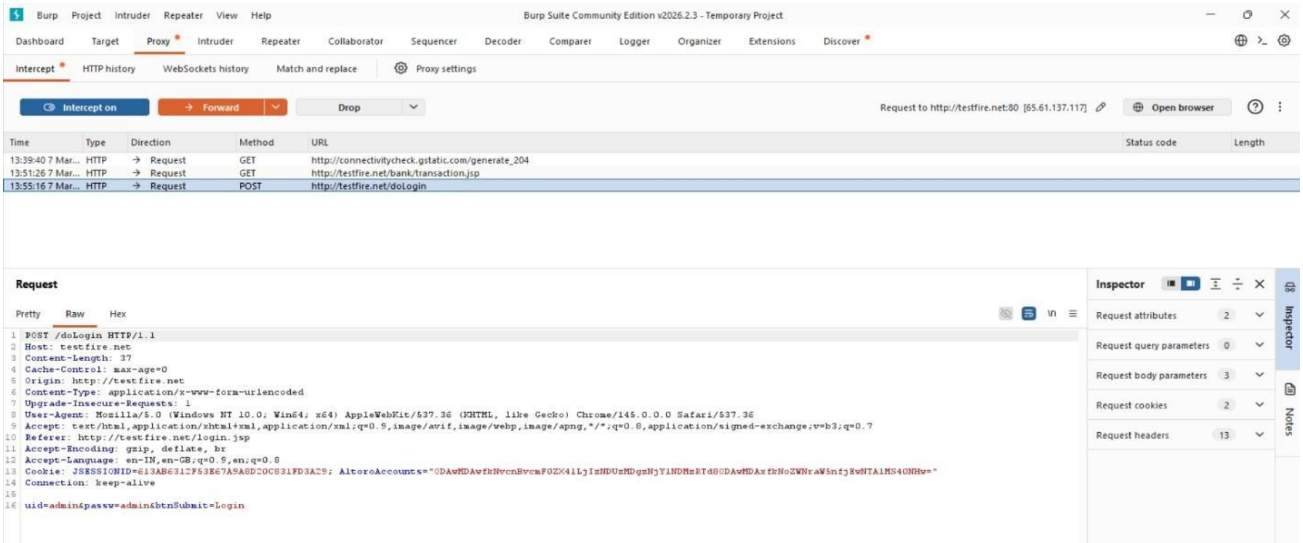
Steps to Reproduce :

1. Open the website **http://testfire.net/**.
2. Login using admin credentials.
3. Capture the request using Burp Suite.
4. The username and password appear in clear text in the request.

Recommendation :

• Use HTTPS with SSL/TLS encryption.
• Ensure sensitive data is always transmitted securely.

Screenshot :



9.Vulnerability Name : Clickjacking

CWE/CVE: - CWE-1021

Description : Clickjacking occurs when a malicious webpage tricks users into clicking hidden buttons or links by placing the target webpage inside an invisible frame.

Business Impact : Attackers can trick users into performing unwanted actions such as clicking buttons, submitting forms, or revealing sensitive information.

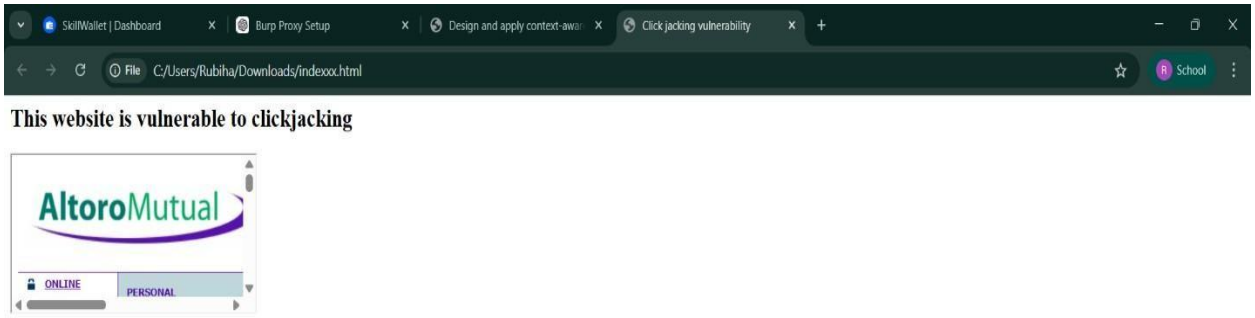
Vulnerability Path : **http://testfire.net/**

Recommendation :

Use X-Frame-Options header to prevent framing.

Implement Content Security Policy (CSP) to block unauthorized embedding.

Screenshot :



10.Vulnerability Name : Web Server Allows Password Auto-Completion

CWE/CVE: - CWE-310

Description : This vulnerability occurs when the web browser automatically fills previously saved usernames and passwords on login pages.

Business Impact : Attackers who gain access to the device can easily view or use stored credentials to access the application.

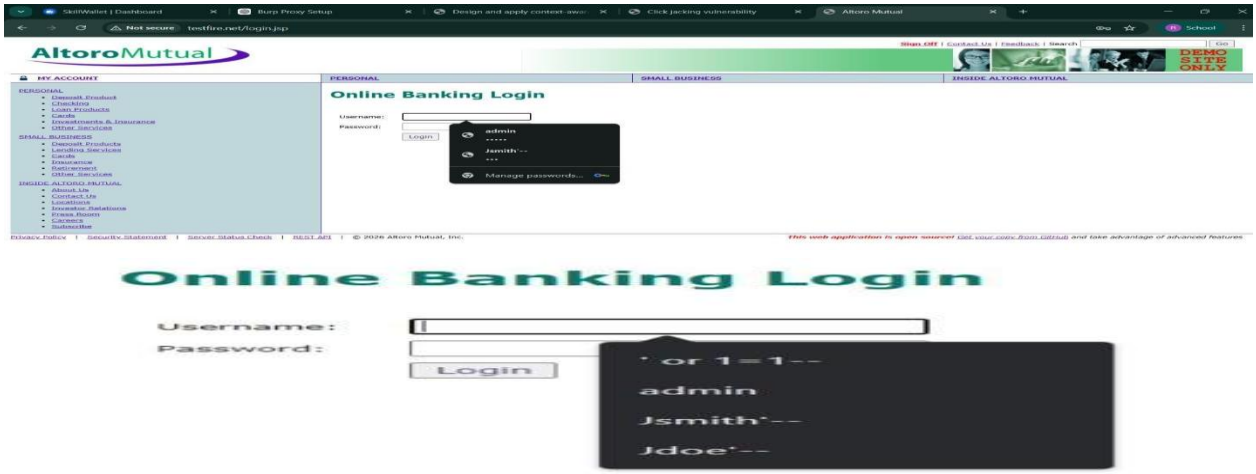
Vulnerability Path : **http://testfire.net/login.jsp**

Recommendation :

Disable password auto-completion on login forms.

Use secure authentication mechanisms.

Screenshot :



STAGE 2

Overview: -

Context-aware access control is a modern cybersecurity approach used to protect applications and organizational systems from unauthorized access. Traditional security mechanisms that rely only on usernames and passwords are not sufficient in today's digital environment where users access systems from different devices and locations. Context-aware access control improves security by evaluating multiple factors before granting access to an application.

In this project, access decisions are based on several parameters such as user identity, device posture, location, and application risk level. The system verifies the identity of the user requesting access and checks whether the device being used is secure and compliant with security policies. It also analyzes the location of the user and evaluates the risk level of the application being accessed.

The system continuously monitors these contextual parameters and decides whether to allow or restrict access. If the conditions meet the defined security policies, the user is granted access to the application. If a potential risk is detected, the system may request additional authentication such as Multi-Factor Authentication (MFA), restrict certain actions, or block the access request.

This approach follows the principles of the Zero Trust Security Model, where every user and device must be verified before access is granted. By implementing context-aware access control, organizations can improve security, protect sensitive information, and prevent unauthorized access to critical systems.

1. Preparation

Define the objectives of the access control system and identify the applications or systems that need protection. Security policies are created based on organizational requirements.

2. Configuration

Access control policies are configured by defining parameters such as user identity verification, device security status, location restrictions, and application risk levels.

3. Access Request

When a user attempts to access an application, the system collects contextual information including user identity, device posture, and location.

4. Context Evaluation

The system analyzes the collected information and compares it with the defined security policies to determine whether the access request is safe.

5. Access Decision

Based on the evaluation, the system decides whether to allow access, request additional authentication, restrict actions, or block the request.

Target Website:- http:// testfire.net

Target IP Address: 54.83.41.36

List of vulnerability

S.NO	Vulnerability name	Severity	plugins
1	Cross-Site Scripting (DOM	Medium	Multiple XSS
2	jQuery 1.3 < 3.5.0 Multiple	Medium	CGI Abuse: XSS
3	Information Exposure (We Header Internal IP Disclose	Low	Webserver HTTP Header Internal IP Disclosure
4	Information Exposure (SSL Multiple Issues)	Info	SSL Certificate Information
5	Information Exposure (HTTP Multiple Issues)	Info	HTTP Information
6	OS Identification Failed	Info	TCP/IP Remote Probing
7	SSL Weak Cipher Suites Supported	Medium	SSL Weak Cipher Suites Detection
8	Missing Security Headers	Low	HTTP Security Header Detection
9	Outdated Web Server Version	Medium	Web Server Version Detection
10	Open Port Detection	Info	TCP Port Scanner

REPORT: -

1. **Vulnerability Name: -** Cross-Site Scripting (DOM Based XSS)

Severity: - Medium

Plugin: - Multiple XSS

Description: - DOM-based Cross-Site Scripting occurs when user input is processed directly in the browser using JavaScript without proper validation or sanitization. This allows attackers to inject malicious scripts that execute in the user's browser. Such attacks can lead to session hijacking, cookie theft, or unauthorized actions performed on behalf of the user. Proper input validation and secure coding practices can help prevent this vulnerability.

Solution: - Implement proper input validation and output encoding to sanitize user inputs before processing in the DOM. Use secure JavaScript practices and apply Content Security Policy (CSP) to prevent script injection.

Business Impact: - Attackers may inject malicious scripts that run in the user's browser. This can lead to session hijacking or theft of sensitive information. It may also damage the organization's reputation and reduce user trust.

2.Vulnerability Name: - jQuery 1.3 < 3.5.0 Multiple XSS

Severity: - Medium

Plugin: - CGI Abuse: XSS

Description: - This vulnerability occurs when a website uses outdated versions of the jQuery library that contain known security flaws. These vulnerabilities can allow attackers to execute Cross-Site Scripting attacks through manipulated inputs. Updating the jQuery library to the latest secure version and regularly maintaining third-party components can help mitigate this issue.

Solution: - Update the jQuery library to version 3.5.0 or higher and regularly maintain all third-party libraries used in the application.

Business Impact: - Attackers may exploit the outdated library to perform Cross-Site Scripting (XSS) attacks. This can lead to data theft or unauthorized actions in user accounts. It may also affect the security and reliability of the web application.

3.Vulnerability Name: - Information Exposure (Web Server HTTP Header Internal IP Disclosure)

Severity:- Low

Plugin: - Webserver HTTP Header

Description: - This vulnerability occurs when the web server exposes internal IP addresses or sensitive system information through HTTP response headers. Attackers can use this information to understand the internal network structure and plan targeted attacks. Configuring the web server to hide internal IP details and unnecessary header information can reduce this risk.

Solution: - Configure the web server to hide internal IP addresses and remove unnecessary HTTP header information. Properly secure and customize server response headers.

Business Impact: - Attackers may obtain internal network details from the exposed headers. This information can help them plan targeted attacks on internal systems. It may increase the risk of further security breaches.

4. Vulnerability Name: - Information Exposure (SSL Multiple Issues)

Severity: Informational

Plugin: - SSL Certificate Information

Description: - This issue indicates that the SSL/TLS configuration of the web server may reveal details about encryption settings or certificates. Although it may not directly lead to exploitation, it provides useful information to attackers about the server's security configuration. Ensuring proper SSL configuration and using strong encryption protocols such as TLS 1.2 or higher can improve security.

Solution: - Ensure certificates are valid, issued by a trusted certificate authority, and properly configured.

Business Impact: - Improper or expired certificates may lead to browser warnings, reduce customer trust, and affect compliance with security standards.

5. Vulnerability Name: - Information Exposure (HTTP Multiple Issues)

Severity: – Informational

Plugin: - HTTP Information

Description: - This vulnerability indicates that the web server exposes additional HTTP information such as server details, protocol versions, or configuration data. Attackers can use this information to identify potential

weaknesses in the system. Reducing unnecessary server information and properly configuring HTTP responses can help prevent such exposure.

Solution: - Configure SSL/TLS properly and use strong encryption protocols such as TLS 1.2 or TLS 1.3. Ensure certificates are valid and securely configured.

Business Impact: - Attackers may gather information about the server's encryption configuration. This information can help them analyze possible weaknesses. It may increase the risk of future security attacks.

6. **Vulnerability Name:** - OS Identification Failed – Informational

Severity: - Informational

Plugin: - TCP/IP Remote Probing

Description: - This issue indicates that the vulnerability scanning tool was unable to accurately identify the operating system of the target server. While this does not represent a direct security vulnerability, it may indicate network filtering, restricted responses, or incomplete system information. Proper configuration and accurate system identification can help improve vulnerability assessment results.

Solution: - Ensure proper network configuration and allow accurate system responses to enable OS detection. Verify scanning settings for completeness.

Business Impact: - Inaccurate OS identification can limit the effectiveness of vulnerability assessments, potentially leaving some security issues undetected. Attackers could exploit unknown gaps in the system.

7. Vulnerability Name: - SSL Weak Cipher Suites Supported

Severity: - Medium

Plugin: - SSL Weak Cipher Suites Detection

Description: - This vulnerability occurs when the web server supports weak or outdated SSL/TLS cipher suites. These ciphers can be exploited by attackers to perform attacks such as eavesdropping, man-in-the-middle attacks, or decrypting sensitive data. Using strong, modern cipher suites like AES-GCM with TLS 1.2 or TLS 1.3 is recommended to ensure secure communications.

Solution: - Disable weak ciphers and enable only strong, recommended TLS cipher suites (TLS 1.2/1.3).

Business Impact: - Using weak ciphers exposes sensitive data to interception and compromise, potentially leading to data breaches, loss of customer trust, and non-compliance with security standards like PCI DSS or HIPAA.

8. **Vulnerability Name: -** Missing Security Headers

Severity: - low

Plugin: - HTTP Security Header Detection

Description: - This vulnerability occurs when a web server does not include important HTTP security headers such as Content-Security-Policy, X-Frame-Options, or X-Content-Type-Options. Missing headers can make applications more susceptible to attacks like clickjacking, MIME-type sniffing, and cross-site scripting.

Solution: - Configure the web server to include essential security headers in all HTTP responses.

Business Impact: - Absence of security headers increases risk of web-based attacks, potentially compromising user data, damaging reputation, and reducing overall trust in the web application.

9.Vulnerability Name: - Outdated Web Server Version

Severity: - Medium

Plugin: - Web Server Version Detection

Description: - This vulnerability occurs when a web server is running an older version that may contain known security flaws. Attackers can exploit these weaknesses to gain unauthorized access, execute code, or disrupt services.

Solution: - Update the web server to the latest stable version and apply security patches regularly.

Business Impact: - Using an outdated server increases the risk of exploitation, leading to potential data breaches, service downtime, and damage to the organization's reputation.

10. **Vulnerability Name: -** Open Port Detection

Severity: - Informational

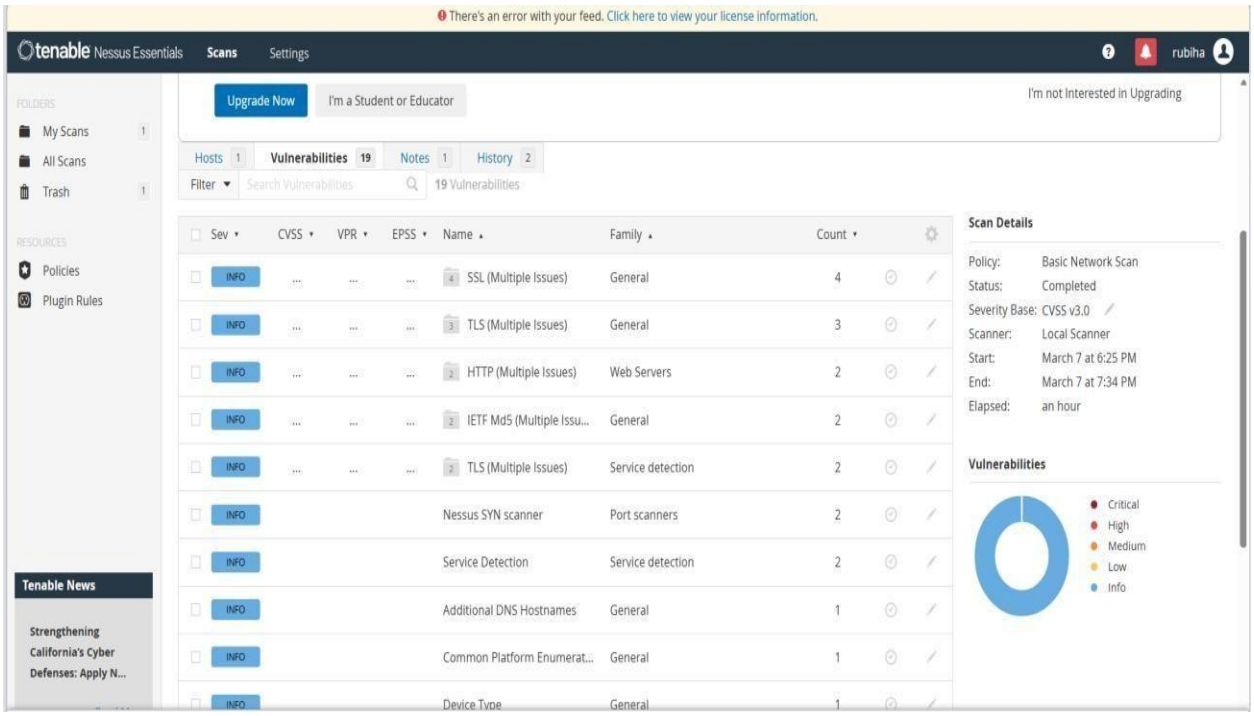
Plugin: - TCP Port Scanner

Description: - This identifies open ports on the target system, which may provide entry points for attackers to exploit services running on those

ports. It helps in mapping the network and assessing potential attack vectors.

Solution: - Close unnecessary ports and restrict access to essential services using firewalls.

Business Impact: - Exposed open ports increase the attack surface, making it easier for attackers to probe and exploit vulnerabilities, potentially compromising network security.



STAGE 3

REPORT

Title: - This report covers the design and implementation of context-aware access controls based on user identity, device posture, location, and application risk in a real-world organizational environment. It explores how such access controls evaluate multiple factors in real time to allow, restrict, or block access, enhancing cybersecurity by enforcing a Zero Trust security model and protecting sensitive applications from unauthorized access.

- **Integration with Zscaler Internet Access (ZIA):**

Integration with Zscaler Internet Access (ZIA) involves combining Private Access (ZPA) and Internet Access to create a unified Secure Access Service Edge (SASE) platform. This integration allows organizations to manage both web and private application traffic through a single consistent policy framework. All traffic is inspected and secured, reducing the attack surface and ensuring secure connectivity for remote users. It simplifies administration by providing a single pane of glass for monitoring access and policy enforcement. Users experience seamless connectivity without compromising security. Policies can be applied based on identity, location, device posture, and application risk. This approach ensures that all users, whether on the internet or internal applications, adhere to the same security standards and monitoring controls.

- **Advanced Device Posture Checking:**

Advanced device posture checking goes beyond traditional compliance checks like antivirus and disk encryption. It incorporates real-time risk scores from endpoint detection and response (EDR) tools to assess the device's current security state. Access can be blocked if a device shows signs of compromise, such as malware infection, suspicious network activity, or outdated patches. This proactive approach reduces the risk of unauthorized access from compromised devices. Organizations can enforce dynamic access policies based on device health and behavior. Continuous monitoring ensures that a device remains compliant throughout the session. Alerts are generated if anomalies are detected, enabling security teams to act swiftly and prevent potential breaches.

- **Privileged Remote Access:**

Privileged remote access extends secure access to third-party vendors, contractors, and privileged users. Instead of relying on jump servers or bastion hosts, ZPA allows time-bound, audited access to specific critical systems. This ensures that external users can only reach the resources necessary for their task. Access is logged and monitored in real time to maintain accountability. Policies can automatically revoke access when the project ends or when a user changes roles. Privileged sessions are isolated, reducing the risk of lateral movement across the network. Additional authentication, like MFA, ensures that only authorized personnel can gain access. This enhances both security and operational efficiency.

- **IoT/OT Segmentation:**

IoT and OT segmentation applies Zero Trust principles to devices like industrial sensors, smart cameras, and operational technology systems. Each device is allowed to communicate only with specific management servers or applications, reducing the risk of lateral movement. Micro-

tunnels are used to isolate IoT/OT traffic from the corporate network while still enabling necessary functionality. Real-time monitoring ensures that any unusual behavior from a device triggers alerts or access restrictions. Policies can enforce device posture checks, ensuring only healthy devices communicate with critical infrastructure. This approach mitigates risks from poorly secured IoT devices, which are often targeted by attackers. Segmentation improves overall network security while maintaining operational continuity and compliance with industry standards.

- **AI-Driven Anomaly Detection:**

AI-driven anomaly detection leverages machine learning algorithms to analyze user behavior patterns in real time. It can detect unusual activities, such as a user accessing an application at an odd hour or from an unexpected location. Based on risk scoring, automated responses like MFA challenges or access revocation can be triggered. The system learns over time, improving its ability to distinguish normal behavior from potential threats. Alerts are generated for suspicious activity, allowing security teams to investigate before incidents escalate. This proactive approach enhances threat detection and reduces response times. By integrating AI with access policies, organizations can prevent breaches caused by compromised credentials or insider threats.

- **Cloud Workload Protection:**

Cloud workload protection ensures secure communication between containers, microservices, and virtual machines across multi-cloud environments like AWS, Azure, and GCP. ZPA encrypts east-west traffic between workloads, ensuring authentication and reducing the risk of lateral movement. Policies can enforce access based on workload identity, location, and risk posture. Security teams gain visibility into inter-service communication and can monitor for unusual activity. Workload segmentation prevents a compromised service from affecting others.

Automated compliance checks ensure workloads adhere to security best practices and organizational standards. This approach protects sensitive data and maintains trust in cloud infrastructure.

- **Automated Provisioning/Deprovisioning:**

Automated provisioning and deprovisioning integrates with identity providers to manage user access dynamically. When an employee is onboarded, access to applications is granted according to their role and risk profile. Conversely, access is immediately revoked if the employee leaves the organization or changes roles. This ensures near real-time enforcement of the least-privilege principle. Automated workflows reduce administrative overhead and prevent human error in access management. Logs are maintained for audit purposes, supporting compliance with regulatory requirements. Security risks are minimized by ensuring that no inactive or unauthorized accounts have lingering access. This process improves both operational efficiency and organizational security posture.

- **Digital Experience Monitoring (DEM):**

Digital Experience Monitoring (DEM) proactively tracks the performance and reliability of applications for end users. It measures metrics like response time, latency, and availability across different networks and devices. DEM tools can detect performance degradation before it impacts productivity, allowing IT teams to resolve issues proactively. Integration with ZPA provides visibility into the impact of network conditions on application access. Alerts and dashboards provide actionable insights for continuous improvement. By monitoring the digital experience, organizations can maintain high service quality while ensuring secure access. This helps in identifying bottlenecks, optimizing performance, and improving user satisfaction.

CONCLUSION

The main objective of this project was to design and apply context-aware access control concepts while performing vulnerability assessment on web applications. With the rapid growth of digital technologies and online services, cybersecurity has become an essential requirement for protecting sensitive data and system resources.

Through this project, various web application vulnerabilities were identified and analyzed using security testing tools. The vulnerability scanning process helped in understanding how attackers exploit weaknesses in web applications and how these vulnerabilities can impact the security of an organization.

The analysis revealed several vulnerabilities including Cross-Site Scripting, outdated software components, information exposure issues, and configuration weaknesses. Each vulnerability highlights the importance of implementing secure coding practices, proper system configuration, and regular security testing.

This project demonstrates the role of vulnerability assessment and security testing in improving application security. By identifying and addressing security weaknesses, organizations can prevent potential cyberattacks, protect user data, and maintain system integrity.

Overall, the project emphasizes the importance of proactive security measures, continuous monitoring, and regular vulnerability scanning to ensure a secure digital environment. Implementing strong security policies and modern access control mechanisms will help organizations protect their systems against evolving cyber threats.

TOOLS USED

The project involved the use of several cybersecurity tools and technologies to perform vulnerability scanning and security analysis. These tools help security professionals identify weaknesses in web applications and understand potential attack vectors.

Kali Linux : -Kali Linux is a penetration testing operating system that contains a large collection of cybersecurity tools used for ethical hacking, vulnerability analysis, and network security testing.

Nessus Vulnerability Scanner: - Nessus is a widely used vulnerability scanning tool that detects security flaws, misconfigurations, and outdated software components in servers and web applications.

Burp Suite: - Burp Suite is a web application security testing tool used to intercept, inspect, and modify HTTP requests and responses between the browser and the web server. It helps identify vulnerabilities such as SQL Injection, Cross-Site Scripting, and authentication issues.

Web Browser: - A web browser such as Google Chrome or Mozilla Firefox is used to access the target web application and perform manual security testing. Browser developer tools help inspect web page elements and analyze scripts.

Uniscan Tool: - Uniscan is a web vulnerability scanning tool used to detect hidden directories, configuration issues, and potential vulnerabilities in web applications. These tools collectively help security analysts perform effective vulnerability assessments and improve the overall security posture of web applications.

—---------THE END —-------